

Grundlagen der IT-Sicherheit Praktikum

SoSe 26

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

Aufgabenblatt 6

Lernziele: Authentifizierungssysteme mit asymmetrischem Schlüssel, One-Time Passwörter

Abgabetermin wird in FELIX bekannt gegeben

Von den vier Aufgaben müssen drei bearbeitet werden

Aufgabe 1 (Einmalpasswörter, TAN-Liste)

Nehmen Sie an, Sie hätten eine Liste mit mehreren Passwörtern erhalten, die Sie für gewisse Aktionen (z.B. eine Banküberweisung) nutzen sollen. Jedes Mal, wenn Sie eine Überweisung starten, wird nach einem Einwegpasswort aus der Liste gefragt. Nach einer erfolgreichen Aktion wird das genutzte Passwort entwertet. Nehmen Sie an, dass ein Angreifer bereits Ihre Login-Daten zum Banksystem kennt.

- Wieso wäre solch ein Verfahren auch dann sicher, wenn ein Angreifer ein einmal genutztes Anmeldepasswort kopieren oder mithören könnte?
- Wäre das Verfahren immer noch sicher, wenn der Angreifer Datenpakete nicht nur mitlesen, sondern auch abfangen, also deren Übertragung zum Ziel stören könnte?
- Könnten Sie sich eine Gegenmaßnahme vorstellen, wie ein Authentifizierungssystem mit Einmalpasswörtern auch unter der Voraussetzung aus Aufgabe 3b) sicher gestaltet werden könnte?
- Listen von Einmalpasswörtern (TAN-Listen) werden kaum noch verwendet. Eine oft verwendete Funktion ist stattdessen die Verifikation über Ihre Bankkarte. Dabei werden die Informationen der Überweisung an Ihre EC-Karte übertragen (optisch oder manuell). Ihre EC-Karte generiert daraufhin ein Einmalpasswort, das Sie eingeben müssen. Wie funktioniert dieses Verfahren? Wieso ist ein solches Verfahren sicher? Sie müssen keine technischen Details beantworten, sondern nur die Grundlegende Idee hinter diesem Verfahren erläutern.

Aufgabe 2

Bei einem Challenge-Response-Verfahren sendet ein Authentifizierungssystem einen Zufallswert und/oder einen Zeitstempel (das sogenannte Challenge) an den Client. Der Client muss dieses Challenge korrekt beantworten.

Ein einfaches Verfahren könnte z.B. so lauten, dass dem übermitteltem Challenge ein Geheimnis (Passwort) hinzugefügt und das Resultat gehast zurückgesandt wird:

Geheimes Passwort (bekannt bei Client und Server) = passwort123

Challenge = aaa

Response = hash(aaapasswort123)

- Wieso sollte solch ein Verfahren genutzt werden?
- Was würde geschehen, wenn das gleiche Challenge mehrfach benutzt wird? Würde dies die Sicherheit des Verfahrens verringern?

- c. Wie könnten Sie sicherstellen, dass so etwas nicht vorkommt oder zumindest sehr unwahrscheinlich wird?
- d. Erstellen Sie einen beispielhaften Ablauf eines solchen Verfahrens. Nutzen Sie eine beliebige Hashfunktion und Challenge. Berechnen Sie die Response entsprechend ihrer gewählten Hashfunktion und dem geteilten Passwort.

Aufgabe 3

- a. Programmieren Sie ein Authentifizierungssystem mit mindestens zwei Benutzern unter Verwendung eines Challenge-Response-Verfahrens. Sie haben die freie Wahl, wie Sie einen Benutzer identifizieren und verifizieren möchten.

Aufgabe 4

In dieser Aufgabe geht es darum einen SSH-Zugang vor Brute-Force-Angriffen zu schützen

- a. Richten Sie sich einen SSH-Server ein: Installieren Sie hierfür eine VM. Die Passwortauthentifizierung muss aktiviert sein. Vergeben Sie den Benutzernamen Alice mit dem Passwort „Apfel“.
- b. Nutzen Sie ein Tool, um einen Brute-Force-Angriff durchzuführen: Lesen Sie sich in das Tool Medusa ein.
- c. Laden Sie ein Wörterbuch herunter und starten Sie damit einen Angriff auf Ihren SSH-Server. Was beobachten Sie? Können Sie sich einloggen?

Nun möchten Sie sich vor Brute-Force-Angriffen schützen. Hierfür benutzen wir fail2ban, ein Tool, welches unterschiedlichste Dienste schützt, indem es die Weiterleitungstabelle manipuliert.

- d. Installieren Sie fail2ban, z.B. mit `apt install fail2ban`
- e. Richten Sie es so ein, dass nach drei Fehlversuchen die IP-Adresse für 60 gesperrt bleibt.
- f. Starten Sie Ihren Brute-Force-Angriff erneut. Was beobachten Sie? Können Sie sich einloggen?
- g. Zeigen Sie die blockierte IP-Adresse an.